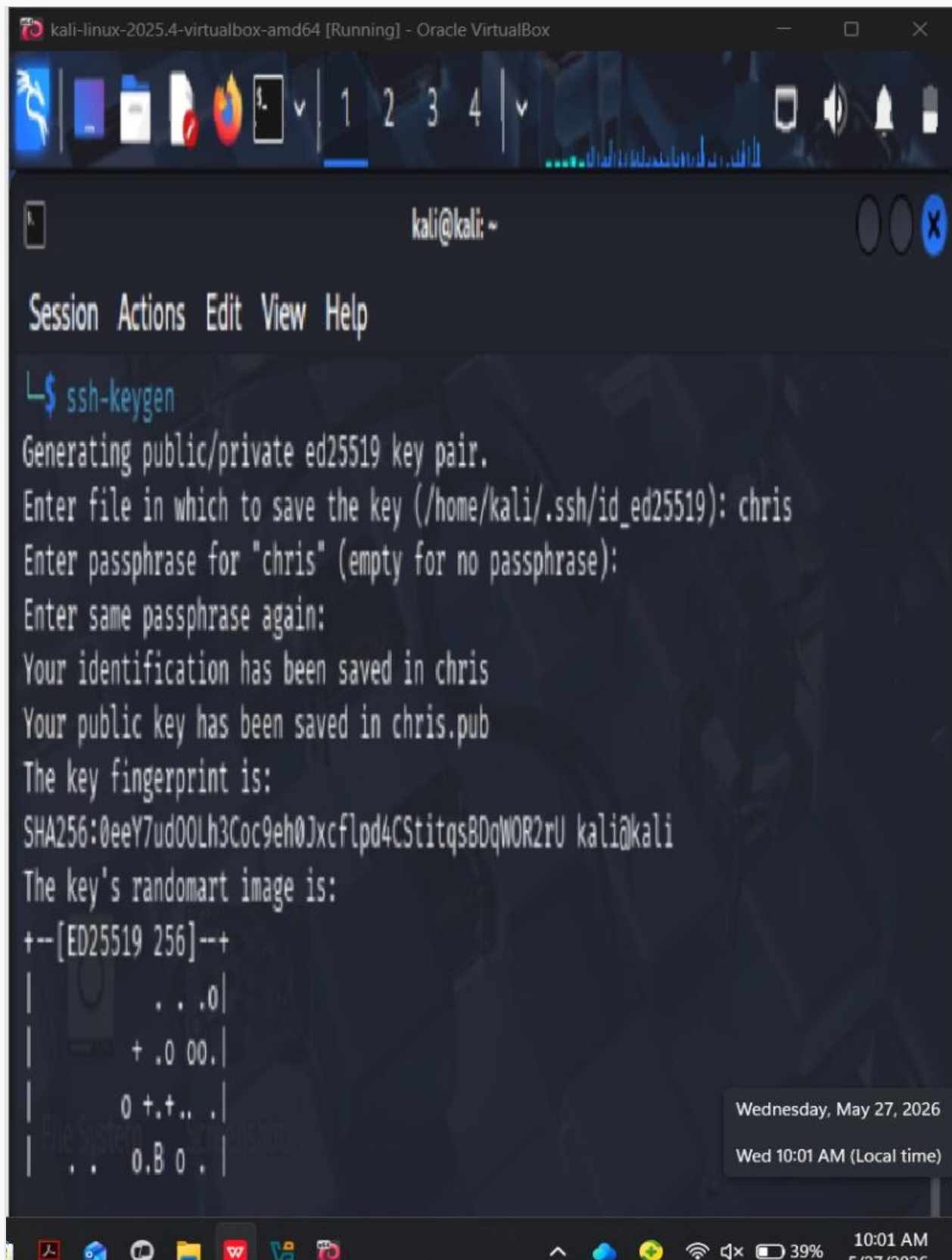


Ethical Hacking Project: Web Application Security Audit

This report documents the security assessment of a local OWASP Juice Shop instance performed in a controlled Kali Linux virtualized environment.

Generating SSH Key



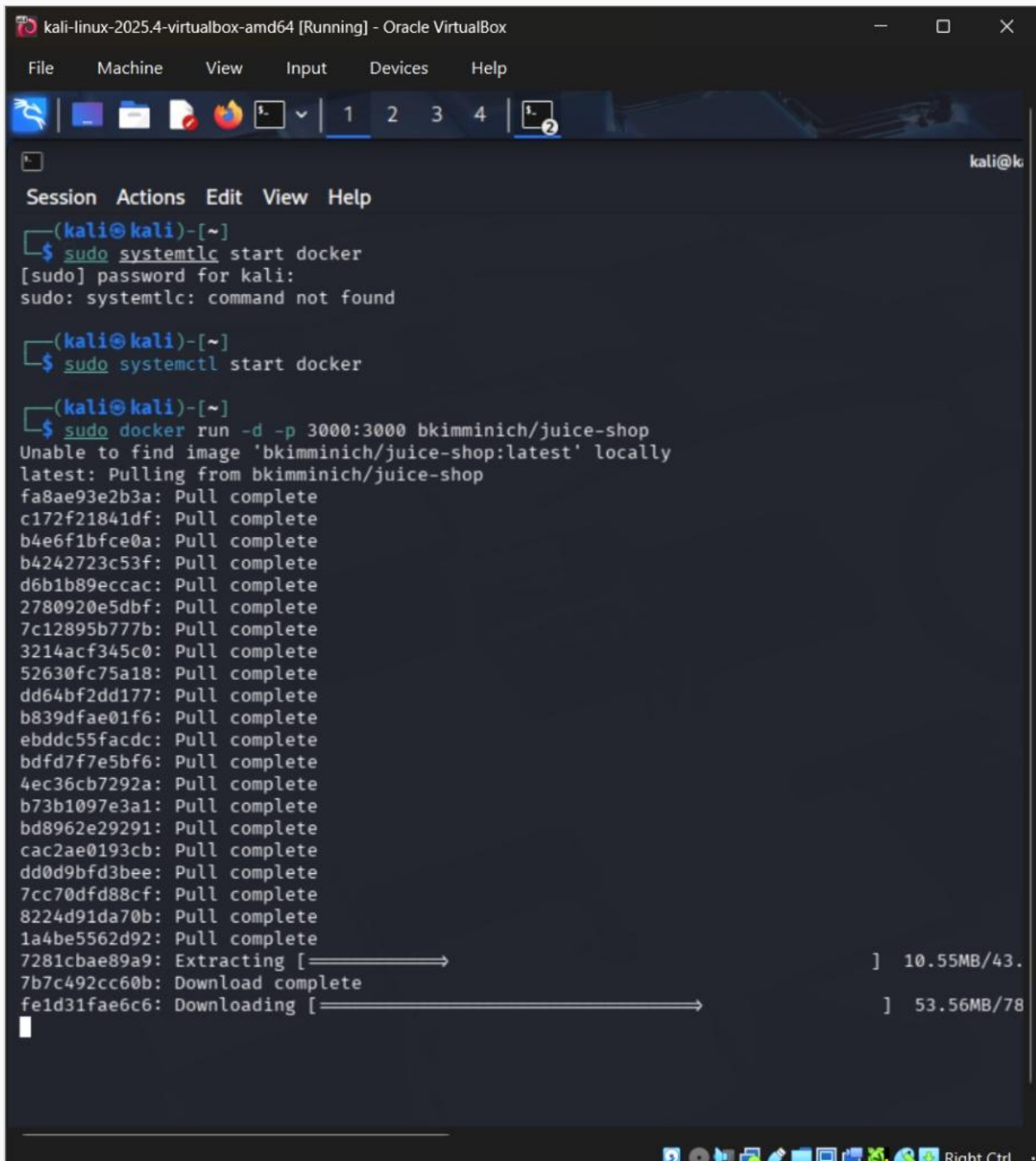
The screenshot shows a terminal window titled "kali-linux-2025.4-virtualbox-amd64 [Running] - Oracle VirtualBox". The terminal prompt is "kali@kali: ~". The user has entered the command "ssh-keygen". The output of the command is as follows:

```
Generating public/private ed25519 key pair.  
Enter file in which to save the key (/home/kali/.ssh/id_ed25519): chris  
Enter passphrase for "chris" (empty for no passphrase):  
Enter same passphrase again:  
Your identification has been saved in chris  
Your public key has been saved in chris.pub  
The key fingerprint is:  
SHA256:0eeY7ud00Lh3Coc9eh0Jxcflpd4CStitqsBDqWOR2rU kali@kali  
The key's randomart image is:  
+--[ED25519 256]--+  
|      . . .0|  
|      + .0 00.|  
|      0 +.+. .|  
|      . . 0.B 0 .|
```

A system clock in the bottom right corner of the terminal window displays "Wednesday, May 27, 2026" and "Wed 10:01 AM (Local time)".

Generating SSH Key

Pulling Juice Shop Docker Container



```
kali-linux-2025.4-virtualbox-amd64 [Running] - Oracle VirtualBox
File Machine View Input Devices Help

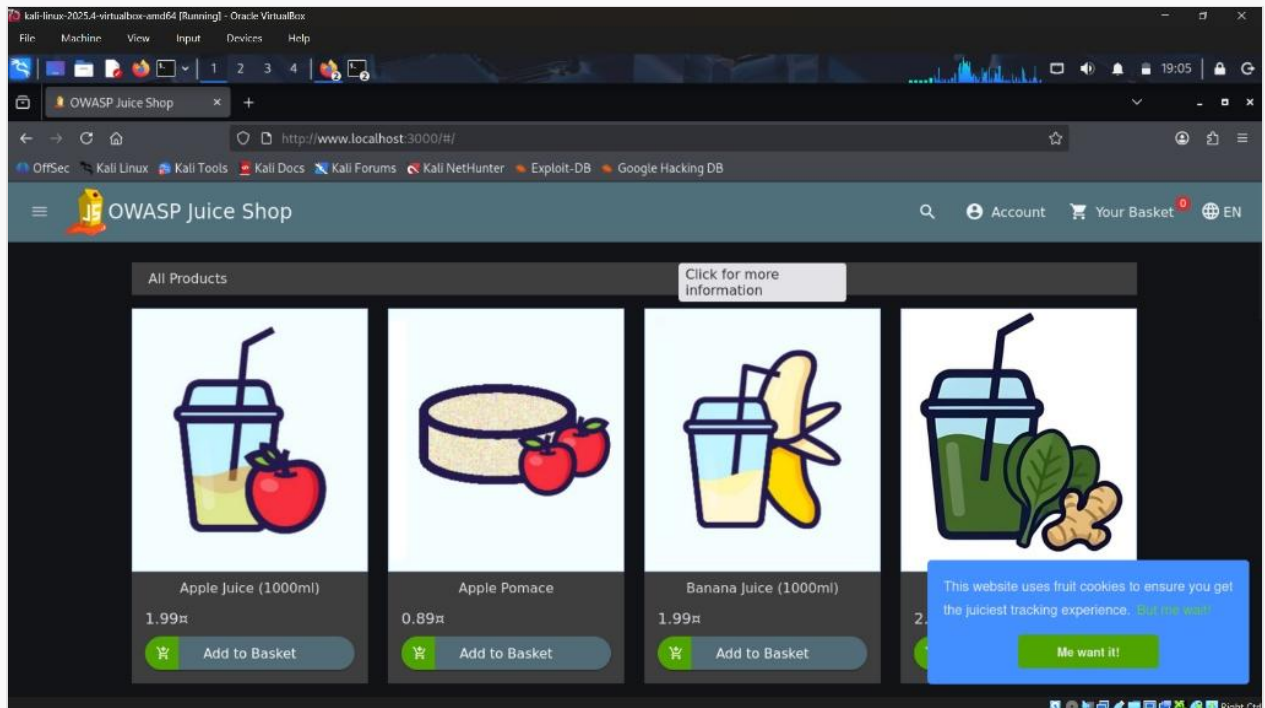
(kali@kali)-[~]
$ sudo systemctl start docker
[sudo] password for kali:
sudo: systemctl: command not found

(kali@kali)-[~]
$ sudo systemctl start docker

(kali@kali)-[~]
$ sudo docker run -d -p 3000:3000 bkimminich/juice-shop
Unable to find image 'bkimminich/juice-shop:latest' locally
latest: Pulling from bkimminich/juice-shop
fa8ae93e2b3a: Pull complete
c172f21841df: Pull complete
b4e6f1bfce0a: Pull complete
b4242723c53f: Pull complete
d6b1b89eccac: Pull complete
2780920e5dbf: Pull complete
7c12895b777b: Pull complete
3214acf345c0: Pull complete
52630fc75a18: Pull complete
dd64bf2dd177: Pull complete
b839dfae01f6: Pull complete
ebddc55facdc: Pull complete
bdfd7f7e5bf6: Pull complete
4ec36cb7292a: Pull complete
b73b1097e3a1: Pull complete
bd8962e29291: Pull complete
cac2ae0193cb: Pull complete
dd0d9bfd3bee: Pull complete
7cc70dfd88cf: Pull complete
8224d91da70b: Pull complete
1a4be5562d92: Pull complete
7281cbae89a9: Extracting [=====] 10.55MB/43.
7b7c492cc60b: Download complete
fe1d31fae6c6: Downloading [=====] 53.56MB/78
```

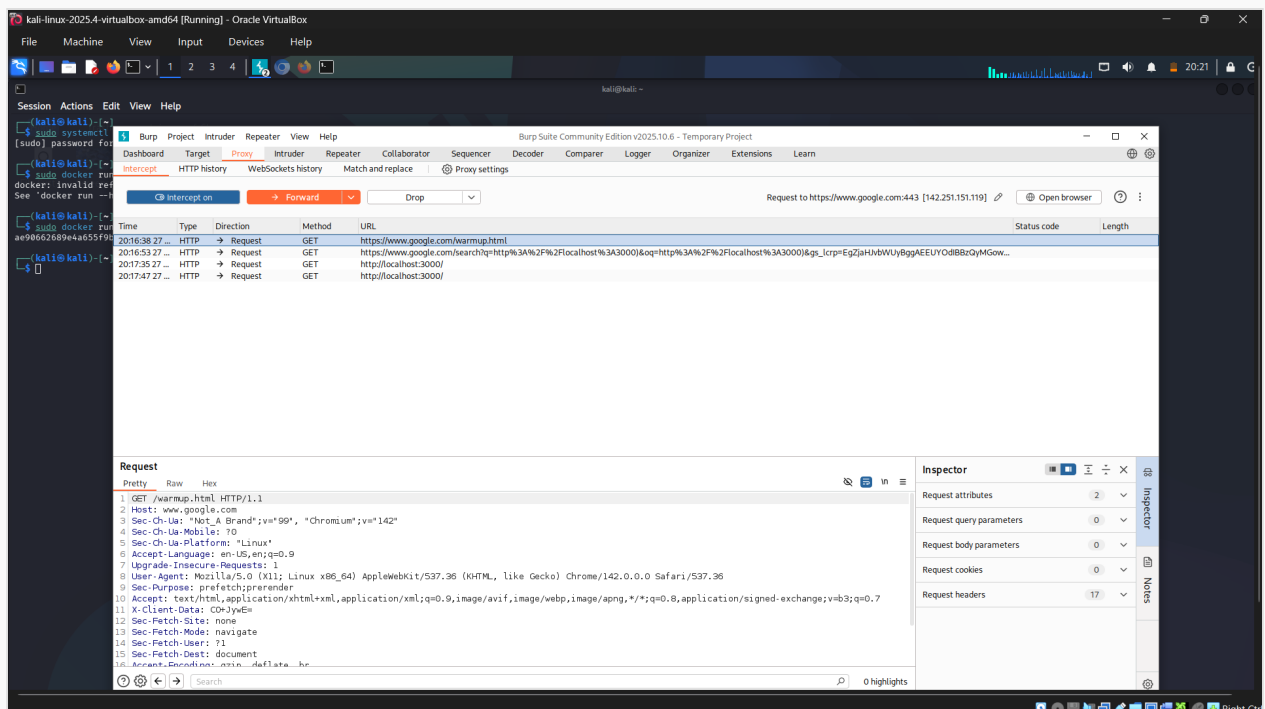
Pulling Juice Shop Docker Container

Juice Shop Application Running



Juice Shop Application Running

Burp Suite Proxy Active



Analyzing HTTP History in Burp Suite

The screenshot displays the Burp Suite Community Edition v2025.10.6 interface. The top menu bar includes File, Machine, View, Input, Devices, and Help. The main toolbar shows various icons for navigation and analysis. The 'Proxy' tab is active, and the 'HTTP history' sub-tab is selected. The history table lists several requests, with the 24th request highlighted. Below the history table, the 'Request' and 'Response' panels are visible. The 'Request' panel shows a GET request to /rest/admin/application-version. The 'Response' panel shows the corresponding JSON response. The 'Inspector' panel on the right provides a detailed view of the request and response headers and body.

#	Host	Method	URL	Params	Edited	Status code	Length	MIME type	Extension	Title
1	https://www.google.com	GET	/warmup.html			404	1782	HTML	html	Error
2	https://www.google.com	GET	/search?q=http%3A%2F%2Flocalhost:3000		✓	200	93735	HTML		Google
3	http://localhost:3000	GET	/			200	10370	HTML		OWASP
4	http://localhost:3000	GET	/			200	10370	HTML		OWASP
5	http://localhost:3000	GET	/			200	10370	HTML		OWASP
22	http://localhost:3000	GET	/socket.io/?EIO=4&transport=pollin...		✓	200	326	text	io/	
23	http://localhost:3000	GET	/assets/i18n/en.json			200	35947	JSON	json	
24	http://localhost:3000	GET	/rest/admin/application-version			200	404	JSON		
25	http://localhost:3000	GET	/rest/admin/application-configurati...			200	23902	JSON		
26	http://localhost:3000	GET	/api/Challenges/?name=Score%20...		✓	200	862	JSON		
27	http://localhost:3000	GET	/rest/languages			200	4603	JSON		
28	http://localhost:3000	GET	/rest/admin/application-version			304	304			

Request

1 GET /rest/admin/application-version HTTP/1.1

2 Host: localhost:3000

3 sec-ch-ua-platform: "Linux"

4 Accept-Language: en-US,en;q=0.9

5 Accept: application/json, text/plain, */*

6 sec-ch-ua: "Not_A Brand";v="99", "Chromium";v="142"

7 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/142.0.0.0 Safari/537.36

8 sec-ch-ua-mobile: ?0

9 Sec-Fetch-Site: same-origin

10 Sec-Fetch-Mode: cors

11 Sec-Fetch-Dest: empty

12 Referer: http://localhost:3000/

13 Accept-Encoding: gzip, deflate, br

14 Connection: keep-alive

15

Response

1 HTTP/1.1 200 OK

2 Access-Control-Allow-Origin: *

3 X-Content-Type-Options: nosniff

4 X-Frame-Options: SAMEORIGIN

5 Feature-Policy: payment 'self'

6 X-Recruiting: /#/jobs

7 Content-Type: application/json; charset=utf-8

8 Content-Length: 20

9 ETag: W/"14-+EBpZnfu193JzIOBjXsY1+KveN8"

10 Vary: Accept-Encoding

11 Date: Thu, 28 May 2026 00:24:02 GMT

12 Connection: keep-alive

13 Keep-Alive: timeout=5

14

15 { "version": "20.0.0" }

Inspector

Request attributes 2

Request headers 13

Response headers 12

[illegible]

WebSockets History and Analysis

Kali Linux - 2025.4 - virtualbox-amd64 [Running] - Oracle VM VirtualBox

File Machine View Input Devices Help

Burp Suite Community Edition v2025.10.6 - Temporary Project

Dashboard Target Proxy Intruder Repeater Collaborator Sequencer Decoder Comparer Logger Organizer Extensions Learn

Intercept HTTP history WebSockets history Match and replace Proxy settings

Intercept on Forward Drop

WebSockets message from https://push.services.mozilla.com/

Time	Type	Direction	Method	URL	Status code	Length
20:31:32 27 May	WS	← To client		http://localhost:3000/socket.io/EIO=4&transport=websocket&sid=CHwVY-N_cF2gzAAAE		
20:31:39 27 May	HTTP	→ Request	GET	http://localhost:3000/socket.io/EIO=4&transport=polling&Pvh_d5g		1
20:32:02 27 May	HTTP	→ Request	GET	http://localhost:3000/socket.io/EIO=4&transport=polling&Pvh_j44		
20:32:03 27 May	HTTP	→ Request	POST	http://localhost:3000/rest/user/login		
20:32:03 27 May	HTTP	→ Request	GET	http://localhost:3000/rest/user/whoami		
20:32:03 27 May	HTTP	→ Request	GET	http://localhost:3000/rest/user/whoami?fields=email		
20:32:27 27 May	HTTP	→ Request	GET	http://localhost:3000/socket.io/EIO=4&transport=polling&Pvh_pA_		
20:37:13 27 May	WS	← To client		https://push.services.mozilla.com/		96

Pretty Raw Hex

```
1 [{"messageType":"broadcast", "broadcasts":{"remote-settings/monitor_changes":"1779920504900"}}]
```

26°C Mostly clear

Search

1:01 AM 5/28/2026

WebSocket Repeater in Action

The screenshot displays the Burp Suite Community Edition v2025.10.6 interface, specifically the WebSocket Repeater tab. The tool is configured for a WebSocket ID of 2 at the URL https://push.services.mozilla.com/. The 'Send WebSocket message' section shows a 'Send' button and a dropdown menu set to 'To client'. A checkbox for 'Select next message received' is checked. The 'Pretty' view of the message shows a JSON object:

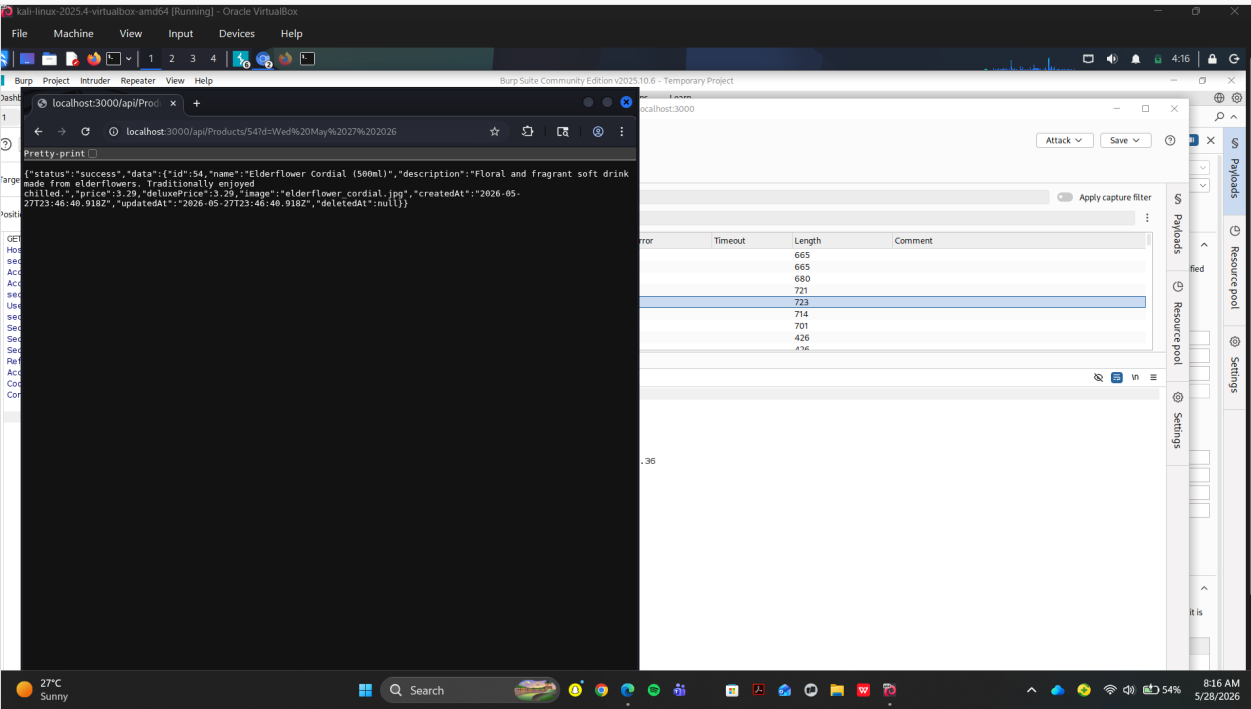
```
1 {
  "messageType": "broadcast",
  "broadcasts": {
    "remote-settings/monitor_changes": "\\1779928584986\\",
  }
}
```

The 'History' tab shows a table of messages:

Message	Direction	Manual	Length	Time	WebSocket ID
["messageType":"broadcast","broadcasts":{"re...	← To client	✓	96	20:37:44 27 May 2026	2
["messageType":"broadcast","broadcasts":{"re...	← To client	✓	96	20:37:49 27 May 2026	2
["messageType":"broadcast","broadcasts":{"re...	← To client	✓	96	20:53:03 27 May 2026	2
["messageType":"broadcast","broadcasts":{"re...	→ To server	✓	96	20:56:24 27 May 2026	2

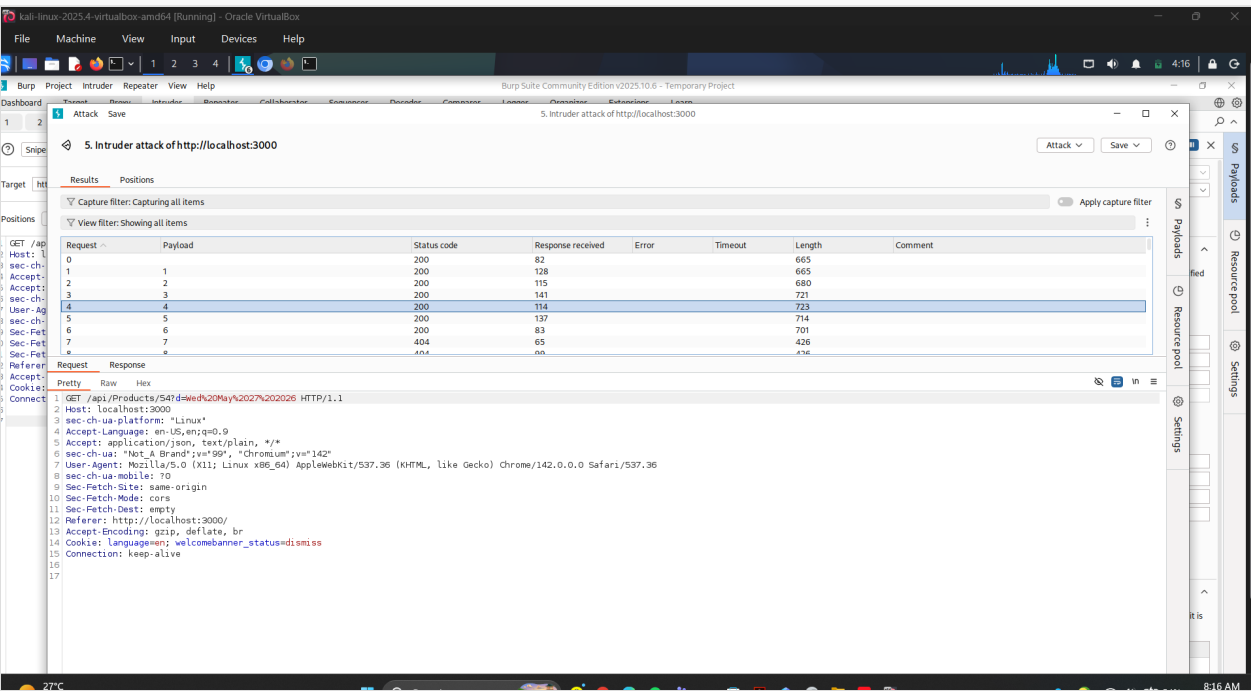
The bottom right of the interface shows the 'Pretty' view of the selected message, which is identical to the one in the 'Send' section.

API Product Detail Analysis



API Product Detail Analysis

Intruder Attack Results



Intruder Attack Results